CRYPTOGRAPHIC THREAT & VULNERABILITY ANALYSIS REPORT

Programme	Enterprise Cryptographic Risk Management Program
Phase	Phase 3 - Threat & Vulnerability Analysis
Scope	Enterprise Digital Certificate Estate
Standard	NIST SP 800-57 (Key Management Recommendation)
Date	16 April 2026
Status	DRAFT - For Internal Review

Table of Contents

1. Executive Summary
2. Scope & Methodology
3. Cryptographic Posture Overview
4. Findings & Risk Analysis
5. Remediation Recommendations
6. Risk Register
7. Appendix

SECTION 1

Executive Summary

A cryptographic asset assessment was conducted across the enterprise certificate estate, inventorying **15 digital certificates** and evaluating each against NIST SP 800-57 cryptographic standards.

The assessment identified significant risk exposure: **27% of certificates (4 of 15)** have expired and remain active in the environment, and **13% (2 of 15)** are protected by RSA-1024 keys which are considered cryptographically weak by current NIST standards.

The overall cryptographic risk posture is rated **Medium-High (6/10)**. The most critical action required is the immediate revocation and removal of all expired certificates, followed by planned remediation of weak key certificates to RSA-2048 or higher.

Overall Risk Rating	Medium-High (6 / 10)
Critical Findings	Expired Certificates
High Findings	Weak Key Certificates
Immediate Action Required	Revoke and remove all 4 expired certificates within 30 days

SECTION 2

Scope & Methodology

Scope

This assessment covered **15 enterprise digital certificates** stored in PEM format (.pem), sourced from the organisation's certificate repository. The assessment focused on Phase 1 of a broader enterprise cryptographic inventory programme, specifically covering X.509 digital certificates.

Methodology

Each certificate was analysed using a custom-built Python-based inventory tool that automatically parsed each PEM file and extracted the following attributes:

Attribute	Description
Common Name (CN)	Identity the certificate is issued to
Issuer	Certificate Authority that issued the certificate
Expiry Date	Date the certificate expires
Key Size	Size of the cryptographic key in bits
Algorithm	Cryptographic algorithm in use (RSA, ECC, DSA)
Status	Valid, Expiring Soon, or Expired
Key Strength	Assessed as Strong or Weak per NIST SP 800-57

Standards Applied

Cryptographic strength was evaluated against **NIST SP 800-57 (Recommendation for Key Management)** using the following minimum key size thresholds:

Algorithm	Minimum Strong Key Size	Assessment Basis
RSA	2048 bits	NIST SP 800-57 Part 1 Rev 5
ECC	256 bits	NIST SP 800-57 Part 1 Rev 5
DSA	2048 bits	NIST SP 800-57 Part 1 Rev 5

SECTION 3

Cryptographic Posture Overview

The following KPIs reflect the current health of the enterprise certificate estate:

KPI	Value	Assessment
Total Certificates Inventoried	15	—
Valid Certificates	11 (73%)	Needs Improvement
Expired Certificates	4 (27%)	Critical
Strong Key Certificates	13 (87%)	Acceptable
Weak Key Certificates	2 (13%)	High Risk
Certificates Expiring Within 30 Days	0 (0%)	No Immediate Risk

Algorithm Distribution

RSA	11	73%
ECC	4	27%
DSA	0	0%

Positive Findings

✓ 87% of certificates use cryptographically strong keys meeting NIST SP 800-57 thresholds.

✓ No certificates are approaching expiry within the next 30 days.

✓ ECC adoption at 27% indicates a positive migration trend toward modern, efficient algorithms.

✓ RSA certificates in use predominantly meet the 2048-bit minimum standard.

SECTION 4

Findings & Risk Analysis

FINDING 1 - Expired Certificates Active in Environment - CRITICAL	
Description	Four digital certificates have passed their expiry date but remain active in the enterprise environment. Expired certificates are no longer considered trustworthy and may contain compromised or unmanaged private keys.
Risk Rating	**Critical**
Business Impact	Expired certificates remaining active in the environment may contain compromised or unmanaged keys. Adversaries could exploit these to establish fraudulent connections, impersonate trusted services, facilitate man-in-the-middle attacks, and intercept sensitive communications - potentially resulting in data breach, financial loss, and reputational damage.
Evidence	See Appendix A - digital_cert_inventory.csv

Affected Certificates:

Certificate	Expiry Date	Algorithm	Key Size	Additional Risk
ee-self-signed	2020-07-28	RSA	2048 bits	Self-signed
foo	2018-03-18	RSA	1024 bits	Weak Key + Expired
CA	2020-12-11	RSA	2048 bits	Root CA Expired
server.example	2016-01-14	RSA	2048 bits	Oldest Expiry

FINDING 2 - Certificates With Weak Cryptographic Keys - HIGH	
Description	Two certificates in the enterprise environment use RSA-1024 keys, which fall below the minimum key strength threshold defined by NIST SP 800-57. Although not immediately exploitable in the same way as expired certificates, they represent a significant cryptographic vulnerability requiring planned remediation.
Risk Rating	**High**
Business Impact	RSA-1024 keys are considered cryptographically broken by NIST standards and are vulnerable to factorisation attacks with modern computing resources. Systems relying on these certificates may establish weak encrypted connections, exposing sensitive data to interception. Additionally, continued use of non-compliant key sizes may result in audit findings during ISMS assessments, potentially impacting regulatory compliance posture.
Evidence	See Appendix A - digital_cert_inventory.csv

Affected Certificates:

Certificate	Expiry Date	Algorithm	Key Size	Status
foo	2018-03-18	RSA	1024 bits	Expired
server.example	2120-10-31	RSA	1024 bits	Valid

SECTION 5

Remediation Recommendations

Finding 1: Expired Certificates - Remediation Steps

Step	Action	Owner	Timeline
1	Revoke all 4 expired certificates with the issuing CA to ensure they are no longer trusted	PKI Team	Within 7 days
2	Verify revocation status is reflected in the Certificate Revocation List (CRL) and OCSP responder	PKI Team	Within 7 days
3	Remove expired certificates from all systems, stores and applications where they are deployed	PKI Team	Within 14 days
4	Initiate certificate renewal - submit CSR to issuing CA, complete validation and install new certificates	PKI Team	Within 30 days
5	Verify new certificates are valid, trusted and operational across all affected systems	PKI Team	Within 30 days

Priority	Owner	Target Completion
Critical - Immediate Action Required	PKI Team	30 days

Finding 2: Weak Key Certificates - Remediation Steps

Step	Action	Owner	Timeline
1	Identify all systems and applications consuming RSA-1024 certificates	PKI Team	Within 14 days
2	Revoke weak key certificates with the issuing CA	PKI Team	Within 21 days
3	Verify revocation status is reflected in CRL and OCSP responder	PKI Team	Within 21 days
4	Remove revoked certificates from all systems and certificate stores	PKI Team	Within 30 days
5	Generate new CSR with minimum RSA-2048 or ECC-256 key strength and submit to issuing CA	PKI Team	Within 35 days
6	Install and deploy new certificates across all affected systems and verify operational status	PKI Team	Within 45 days

Priority	Owner	Target Completion
High - Remediate After Finding 1	PKI Team	45 days

SECTION 6

Risk Register

The following risk register provides a consolidated view of all cryptographic findings, enabling ongoing tracking and management of remediation activities.

ID	Finding	Risk Rating	Owner	Timeline	Status
CR-001	4 Expired Certificates Active in Environment	Critical	PKI Team	30 days	In Remediation
CR-002	2 Weak Key Certificates (RSA-1024)	High	PKI Team	45 days	Planned

Risk Register Summary

Total Findings	Critical	High	Medium	Low
2	1	1	0	0

SECTION 7

Appendix

Appendix A - Cryptographic Asset Inventory

Full certificate inventory generated by the Phase 1 Python scanning tool. Contains all 15 certificates with extracted attributes and risk assessments.

File: **digital_cert_inventory.csv**

Appendix B - Crypto Posture Dashboard

Live visual dashboard showing KPIs, KRIs, certificate status distribution, key strength breakdown and algorithm distribution. Generated dynamically from the Phase 1 inventory CSV.

URL: **https://sai-subhikshaa.github.io/crypto-asset-inventory/phase-2-dashboard/dashboard.html**

Appendix C - Tool Source Code

Full source code for the Phase 1 certificate inventory tool and Phase 2 dashboard generator is available on GitHub.

Repository: **https://github.com/Sai-Subhikshaa/crypto-asset-inventory**